CYBER AWARENESS MONTH · ICS / OT / IoT

Cyber-Physical “Spot the Issue” Catalog

A field companion to the corporate-office awareness scene — for operational technology. 15 field scenarios across manufacturing, oil & gas, electric, natural gas, maritime and buildings & facilities, each seeded with cyber, safety and good-practice findings and flagged to IEC 62443-3-3, IEC 62443-4-2, the Secure PLC Coding Top 20 and ISA-TR84.00.09 v3.

How to use it

1. Each scene hides eight numbered findings. Learners spot the numbered markers and call out what looks wrong.
2. The table under each scene is the answer key — what to look for, the finding type, and the standards it maps to.
3. Run it as a quiz: hold the key back and let the group find all eight, or reveal one item at a time.

Finding type

● Cyber ● Safety / cyber-physical ● Good practice

Standards flagged

3-3 IEC 62443-3-3 (system security requirements)
4-2 IEC 62443-4-2 (component security requirements)
PLC Secure PLC Coding Practices – Top 20
84.09 ISA-TR84.00.09 v3 (cybersecurity & the functional-safety lifecycle)

Scenarios in this catalog

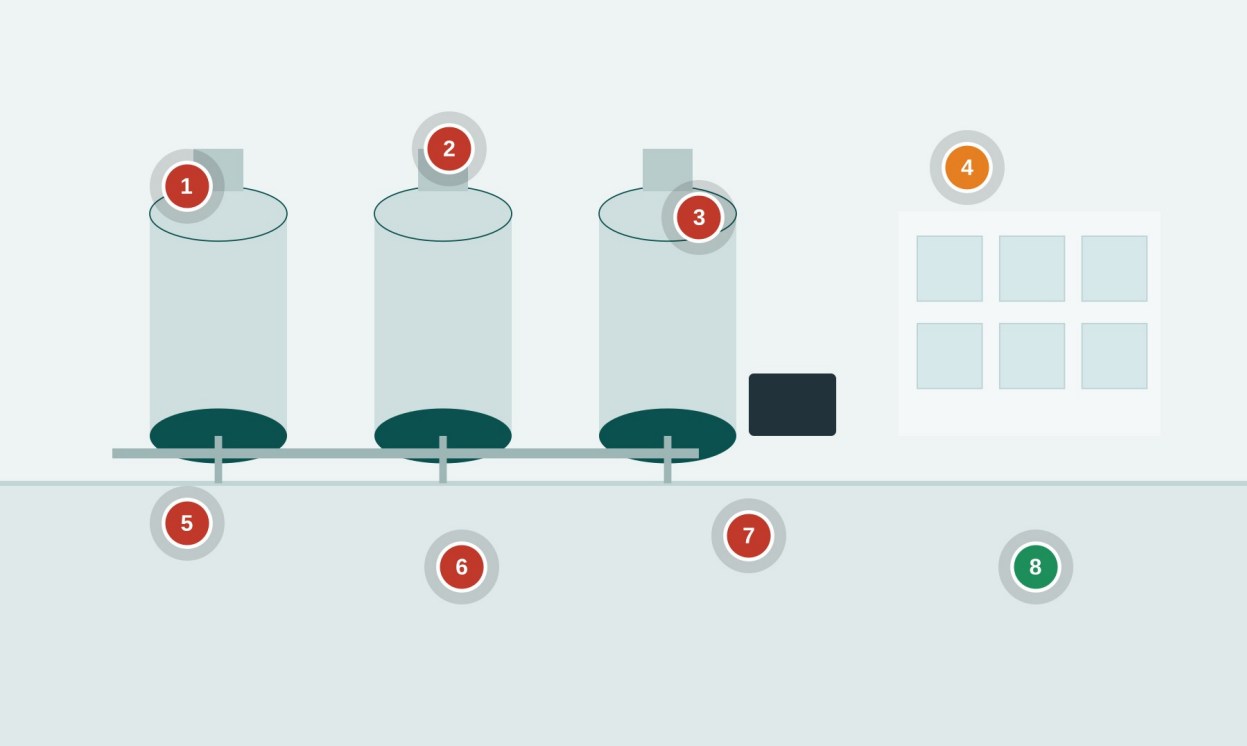
1. **Manufacturing —** Pharma / Biotech Manufacturing Plant
2. **Oil & Gas —** Oil & Gas — Upstream Wellpad & Drilling
3. **Oil & Gas —** Oil & Gas — Midstream Pump Station & Tank Farm
4. **Oil & Gas —** Oil & Gas — Downstream Refinery & Control Room
5. **Oil & Gas —** Oil & Gas — Offshore Platform & Helicopter Transfer
6. **Electric —** Electric — Transmission Substation
7. **Electric —** Electric — Smart Meters & Distribution Automation
8. **Natural Gas —** Natural Gas — Farm Tap, Pipeline Station & Compression
9. **Natural Gas —** Natural Gas — LNG Terminal
10. **Maritime —** Maritime — Vessel Bridge & Engine Room
11. **Maritime —** Maritime — Port & Container Terminal
12. **Buildings & Facilities —** Data Center — Cooling & Mechanical Plant
13. **Buildings & Facilities —** Buildings — Automation & Boiler Plant
14. **Buildings & Facilities —** Buildings — Fire & Life Safety Systems
15. **Buildings & Facilities —** Buildings — Physical Access Control & Security

On the standard IDs. IEC 62443-3-3 (SR), 62443-4-2 (CR/EDR/HDR/NDR) and the Secure PLC Coding Top 20 (#) are cited by exact requirement/item ID and name. ISA-TR84.00.09 v3 items are flagged by their security-lifecycle element and the IEC 61511 phase they sit in (Analysis / Realization / Operation); confirm exact clause numbers against your controlled copy of v3. Finding types and standard mappings are teaching aids, not a compliance assessment.

MANUFACTURING

Pharma / Biotech Manufacturing Plant

Bioreactor cleanroom suite — DCS/MES, serialization line, batch records



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A GMP bioreactor and cleanroom suite. Operators run a batch from HMIs on a process DCS; an MES pulls recipes and writes electronic batch records; a serialization/packaging line runs downstream; a bioreactor SIS protects against over-pressure and runaway reactions.

Key OT/IoT assets: Bioreactor / fermenter PLCs · Process DCS + operator HMIs · MES & OT historian · Serialization / packaging line PLC · Bioreactor SIS (over-pressure trip) · CIP (clean-in-place) skid · Engineering workstation (EWS)

People & roles: Batch/process operator · Manufacturing / automation engineer · QA (batch release) · Contract validation engineer · Maintenance technician

Processes: Batch execution & recipe download · Change control / MOC · Data historian & batch review · Cleaning validation (CIP) · SIS proof testing

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**Shared HMI login** Cyber HMI signed in with a shared 'operator' account; no per-user identity, so batch actions can't be attributed.	`3-3 SR 1.1` Human user identification and authentication `4-2 CR 1.1` Human user identification and authentication `84.09 Operation` SIS access control and independence from the BPCS
2	**Recipe editable at HMI** Cyber Batch/recipe parameters can be changed directly at the HMI with no authorization step or second check.	`3-3 SR 2.1` Authorization enforcement `3-3 SR 3.4` Software and information integrity `PLC #8` Validate HMI input variables at the PLC level, not only at the HMI

#	What to look for	Standards flagged — requirement ID & name
3	**Laptop + USB on DCS** Cyber Unmanaged engineering laptop and USB drive plugged straight into the control cabinet / engineering port.	3-3 SR 2.3 Use control for portable and mobile devices 4-2 CR 2.13 Use of physical diagnostic and test interfaces 3-3 SR 3.2 Malicious code protection
4	**SIS trip bypassed** Safety Bioreactor over-pressure trip left in BYPASS with no management-of-change record.	84.09 Operation Bypass / override management for the SIS PLC #2 Track operating modes PLC #15 Define a safe process state in case of a PLC restart
5	**Flat MES/OT network** Cyber MES/IT and bioreactor PLCs share one flat VLAN — no zone boundary between business and process.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 CR 5.1 Network segmentation
6	**Default vendor password** Cyber PLC/HMI still on the default vendor credential printed on a sticky note.	3-3 SR 1.5 Authenticator management 3-3 SR 1.7 Strength of password-based authentication 4-2 CR 1.7 Strength of password-based authentication
7	**Historian export to USB** Cyber Contractor exports historian/batch data to a personal USB drive with no control on the data flow.	3-3 SR 4.1 Information confidentiality 3-3 SR 5.3 General purpose person-to-person communication restrictions 3-3 SR 2.3 Use control for portable and mobile devices
8	**Signed serialization code** Good practice GOOD PRACTICE: serialization line PLC runs a checksum / integrity check on its program and alarms on change.	PLC #5 Use cryptographic and/or checksum integrity checks for PLC code 3-3 SR 3.4 Software and information integrity

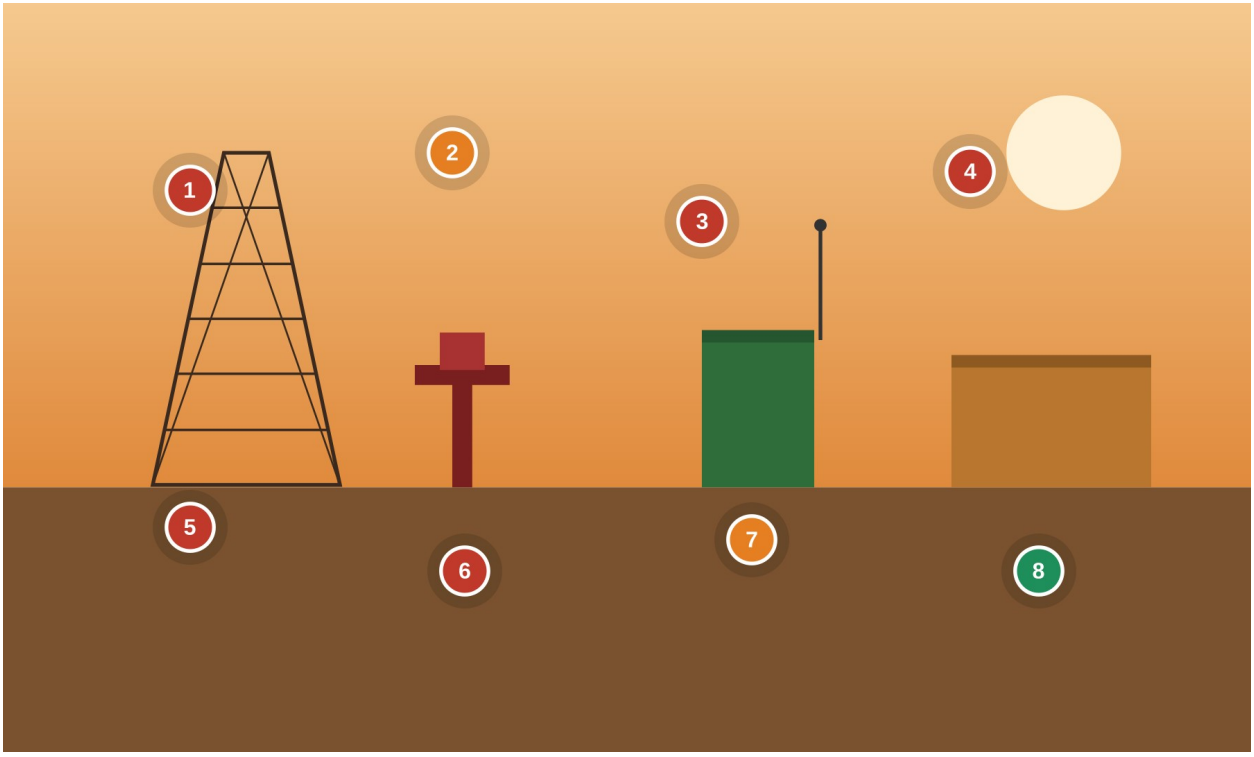
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide-angle shot inside a pharmaceutical bioreactor cleanroom, stainless-steel fermenter tanks and piping, an operator in a white gown and hairnet at a large HMI touchscreen. Visible tells for a 'spot the cyber-physical issue' training scene: the HMI shows a shared login 'operator / operator', a yellow sticky note on the panel reads 'PLC pw: Vendor123', a red-tagged SIS bypass switch is flipped to BYPASS with an alarm banner 'HIGH PRESSURE TRIP INHIBITED', an engineering laptop is plugged into the control cabinet by a USB cable with a USB thumb drive next to it, an unlocked network switch cabinet with IT and OT cables mixed together, a whiteboard reading 'Recipe params — edit at HMI OK'. Bright clinical lighting, shallow depth of field, realistic industrial detail, no text overlays or annotations.
```

OIL & GAS Oil & Gas — Upstream Wellpad & Drilling

Remote wellpad — RTU/flow computer, wellhead ESD, drilling rig, cellular SCADA



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A remote wellpad with a drilling rig doghouse. A field RTU / flow computer telemeters production over a cellular/satellite link to a central SCADA; the wellhead has an emergency shutdown (ESD) valve; H2S gas detection protects crews.

Key OT/IoT assets: Field RTU / flow computer · Wellhead ESD valve · Drilling rig control (doghouse) · Cellular / satellite SCADA modem · H2S gas detection · Custody metering · RTU enclosure / cabinet

People & roles: Pumper / lease operator · Drilling crew (driller, roughnecks) · SCADA / automation tech · Third-party service contractor · HSE / safety officer

Processes: Production telemetry & polling · Well control & ESD · Custody transfer measurement · Contractor turnaround work · Gas-detection alarm response

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**RTU exposed to internet** Cyber Cellular RTU reachable directly from the internet with no VPN; remote polling over an untrusted network.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 5.2 Zone boundary protection 4-2 CR 3.1 Communication integrity
2	**ESD in manual bypass** Safety Wellhead emergency-shutdown valve tagged into MANUAL BYPASS — safety function defeated.	84.09 Operation Bypass / override management for the SIS PLC #2 Track operating modes PLC #15 Define a safe process state in case of a PLC restart
3	**Plaintext Modbus/SNMP** Cyber Flow computer polled over plaintext Modbus with default SNMP community; values readable and writable.	3-3 SR 3.1 Communication integrity 3-3 SR 4.3 Use of cryptography PLC #13 Disable unused / unneeded communication ports and protocols

#	What to look for	Standards flagged — requirement ID & name
4	**Contractor Wi-Fi laptop** Cyber Service contractor's unmanaged laptop joins the drilling control network over shared Wi-Fi.	3-3 SR 2.3 Use control for portable and mobile devices 3-3 SR 1.6 Wireless access management 4-2 NDR 1.6 Wireless access management
5	**Shared creds on sticky note** Cyber Shared SCADA/radio credentials written on a sticky note in the doghouse.	3-3 SR 1.5 Authenticator management 3-3 SR 1.7 Strength of password-based authentication 3-3 SR 1.1 Human user identification and authentication
6	**Open RTU cabinet** Cyber RTU enclosure padlock open and door ajar; controller and diagnostic port physically exposed.	4-2 EDR 3.11 Physical tamper resistance and detection 4-2 CR 2.13 Use of physical diagnostic and test interfaces
7	**H2S detector disabled** Safety H2S gas detector bagged and alarm disabled — life-safety detection defeated.	PLC #20 Trap false negatives and false positives for critical alerts PLC #7 Validate and alert for paired inputs / outputs 3-3 SR 6.2 Continuous monitoring
8	**Signed RTU firmware** Good practice GOOD PRACTICE: RTU fleet has an asset inventory with signed, verified firmware updates.	3-3 SR 7.8 Control system component inventory 4-2 EDR 3.10 Support for updates 4-2 EDR 3.14 Integrity of the boot process

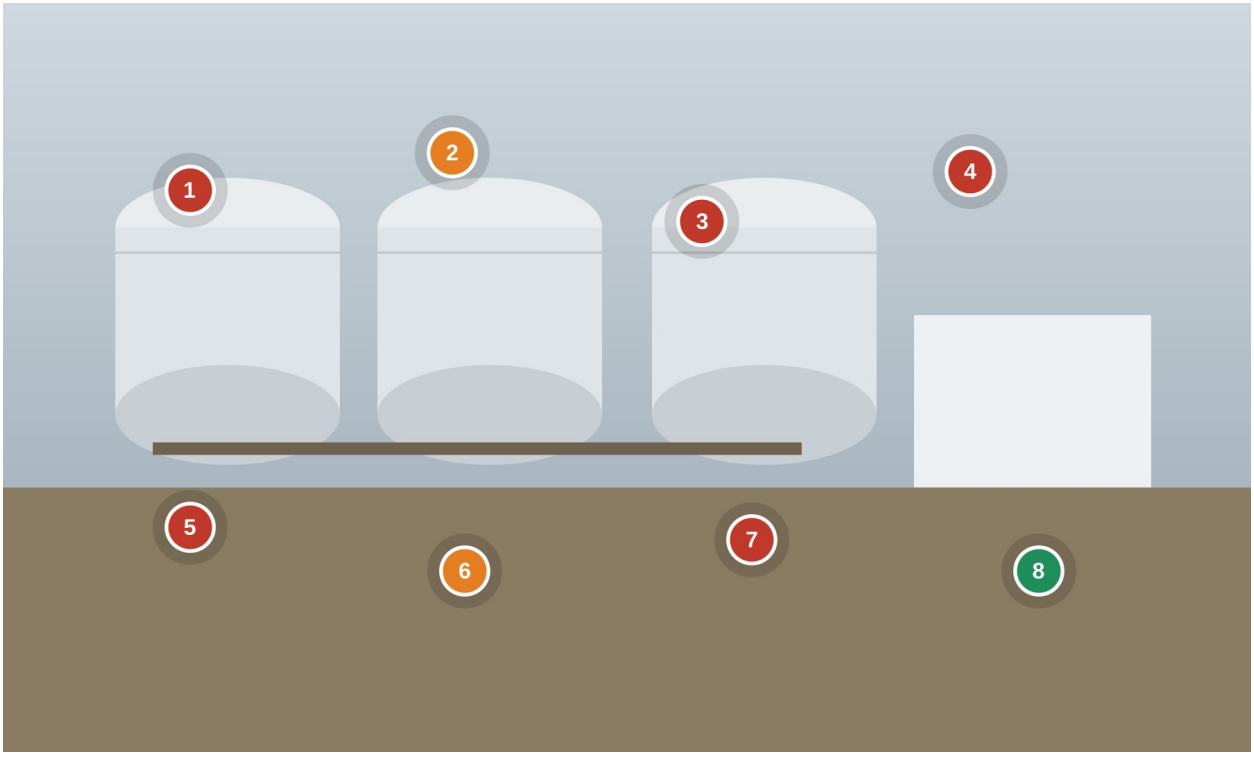
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide shot of a remote oil & gas wellpad at dusk, a drilling rig derrick and a wellhead 'Christmas tree' with red ESD valve, a small green metal RTU cabinet on a skid with a whip cellular antenna. Training tells: the RTU cabinet padlock hangs open and the door is ajar exposing a controller, a laptop sits on the cabinet connected by an Ethernet cable, a sticky note on the doghouse window reads 'SCADA radio: admin / admin', the wellhead ESD handwheel has a 'MANUAL BYPASS' tag zip-tied to it, an H2S gas detector head has a plastic bag over it and a red 'ALARM DISABLED' tag, a cellular router with a public IP label. Golden-hour lighting, dust, realistic oilfield detail, no text overlays or annotations.
```

OIL & GAS Oil & Gas — Midstream Pump Station & Tank Farm

Pipeline pump station — SCADA, mainline pumps, custody metering, tank overfill SIS



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A crude pipeline pump station and tank farm. SCADA drives mainline pump VFDs; custody metering measures transfers; storage tanks are protected by an overfill-prevention SIS and high-high level alarms; a leak-detection system watches the line.

Key OT/IoT assets: Pipeline SCADA + HMI server · Mainline pump VFD PLCs · Custody metering flow computers · Tank overfill SIS + high-high level · Leak-detection system · SCADA historian

People & roles: Pipeline controller (control center) · Station operator · Measurement technician · SCADA engineer · Vendor remote support

Processes: Pipeline batching & pump control · Tank gauging & overfill protection · Custody transfer measurement · Leak detection & response · Remote vendor support

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**Remote access open to internet** Cyber Pipeline SCADA reached via always-on TeamViewer/RDP exposed to the internet.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 2.6 Remote session termination 3-3 SR 5.2 Zone boundary protection
2	**Tank overfill trip inhibited** Safety Tank overfill-prevention SIS bypassed and high-high level alarm inhibited (Buncefield-type exposure).	84.09 Operation Bypass / override management for the SIS PLC #7 Validate and alert for paired inputs / outputs PLC #12 Validate inputs based on physical plausibility
3	**Writable custody metering** Cyber Custody flow computer on unsecured Modbus; measurement values can be written/spoofed (fraud).	3-3 SR 3.1 Communication integrity 3-3 SR 3.5 Input validation PLC #14 Restrict third-party data interfaces

#	What to look for	Standards flagged — requirement ID & name
4	**Flat pump network** Cyber Mainline pump VFD PLCs share a flat network with the corporate historian; no segmentation.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 CR 5.1 Network segmentation
5	**Weak SCADA credentials** Cyber Shared SCADA HMI login on a weak password; no multi-factor for control access.	3-3 SR 1.1 Human user identification and authentication 3-3 SR 1.7 Strength of password-based authentication 3-3 SR 1.5 Authenticator management
6	**Leak detection muted** Safety Leak-detection system left in maintenance/muted state — no alerting on a release.	PLC #2 Track operating modes PLC #20 Trap false negatives and false positives for critical alerts 3-3 SR 6.2 Continuous monitoring
7	**Unpatched SCADA server** Cyber Windows SCADA server unpatched with no anti-malware / application allow-listing.	3-3 SR 3.2 Malicious code protection 3-3 SR 7.6 Network and security configuration settings 4-2 HDR 3.2 Malicious code protection
8	**DMZ + one-way historian** Good practice GOOD PRACTICE: segmented DMZ with unidirectional replication of historian data to enterprise.	3-3 SR 5.2 Zone boundary protection 3-3 SR 5.1 Network segmentation 3-3 SR 6.1 Audit log accessibility

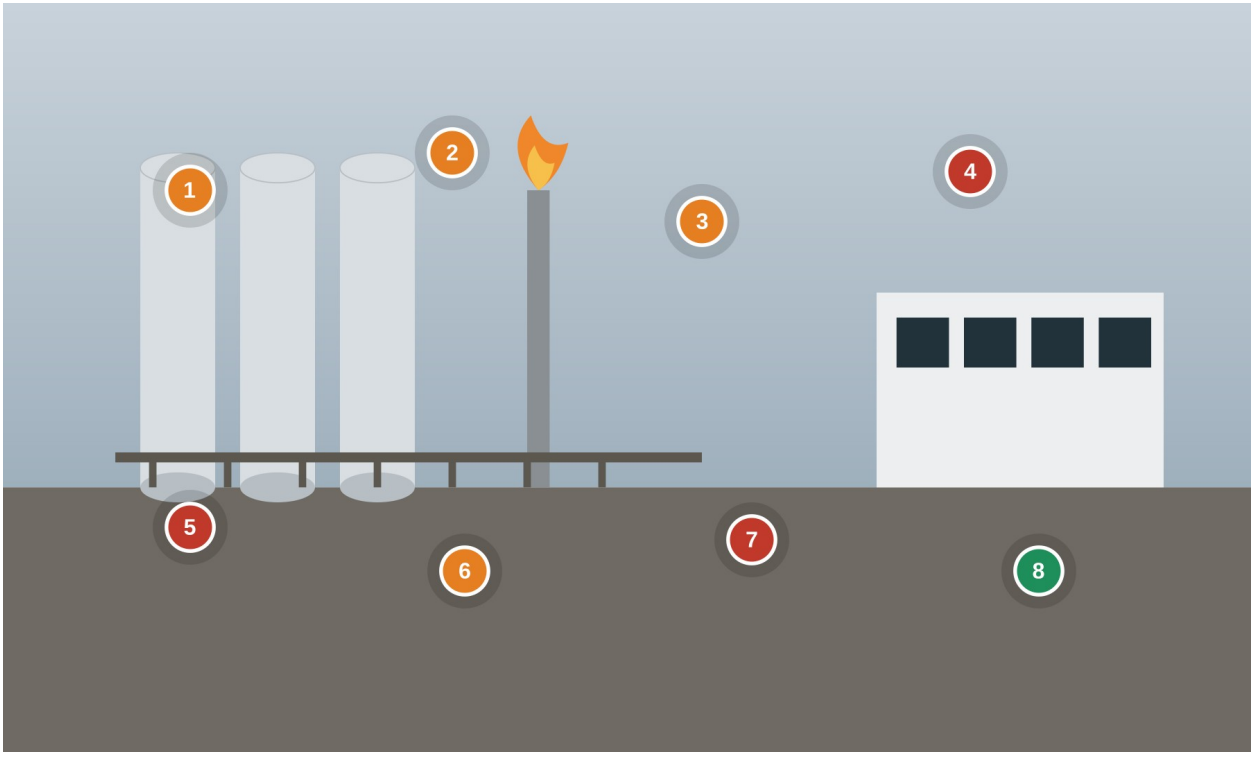
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide shot of a crude-oil pipeline pump station and tank farm, large white storage tanks, mainline pump skids and pipe manifolds, a small control building. Training tells: a control room monitor shows a remote-access session labelled 'TeamViewer — always on', a tank gauge panel reads 'HIGH-HIGH LEVEL ALARM INHIBITED', a metering cabinet is open with a laptop wired in, a monitor shows 'Leak detection: MAINTENANCE / muted', a sticky note 'SCADA: operator / Password1', a network rack with IT and OT switches cabled together, an overflowing-looking tank near the top gauge. Overcast industrial lighting, realistic midstream detail, no text overlays or annotations.
```

OIL & GAS Oil & Gas — Downstream Refinery & Control Room

Refinery process unit — DCS control room, BPCS/SIS separation, furnace & flare



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A refinery process unit run from a central control room. A DCS (BPCS) drives the process; an independent SIS provides trips for furnaces, columns and compressors; operators work consoles under alarm management; vendors provide remote support.

Key OT/IoT assets: DCS / BPCS + operator consoles · Independent SIS + logic solver · SIS engineering workstation · Furnace / heater trips · Flare & relief system · Alarm management system

People & roles: Board operator · Outside operator · Process control engineer · Functional safety engineer · DCS/SIS vendor (remote)

Processes: Process control (BPCS) · Safety instrumented functions (SIS) · Alarm management & rationalization · Management of change · Vendor remote support

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**BPCS & SIS not separated** Safety BPCS and SIS share controllers/network with no independence between control and safety.	84.09 **Realization** SIS zones and conduits (SIS as a separate zone) 3-3 **SR 5.1** Network segmentation 3-3 **SR 5.4** Application partitioning
2	**SIS key-switch in PROGRAM** Safety SIS logic-solver key-switch left in PROGRAM/REMOTE, allowing online logic changes.	PLC **#2** Track operating modes 84.09 **Realization** Security verification & validation of the SIF 4-2 **CR 2.13** Use of physical diagnostic and test interfaces
3	**Furnace trip forced** Safety Furnace/heater trip forced/bypassed on the DCS with no compensating measures.	84.09 **Operation** Bypass / override management for the SIS PLC **#15** Define a safe process state in case of a PLC restart 3-3 **SR 2.1** Authorization enforcement

#	What to look for	Standards flagged — requirement ID & name
4	**Unlocked shared console** Cyber Control-room console unlocked and unattended on a shared login; no session lock.	3-3 SR 2.5 Session lock 3-3 SR 1.1 Human user identification and authentication 4-2 CR 2.5 Session lock
5	**Always-on vendor VPN** Cyber Vendor remote-support VPN left permanently connected with no time limit or monitoring.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 2.6 Remote session termination 4-2 NDR 5.2 Zone boundary protection
6	**Alarm flood / shelved alarms** Safety Alarm system flooded; nuisance alarms shelved, masking real safety alarms.	PLC #20 Trap false negatives and false positives for critical alerts 3-3 SR 6.2 Continuous monitoring 84.09 Operation Management of change (MOC) for SIS security
7	**USB IT->DCS transfer** Cyber USB drive used to move patches/graphics from IT into the DCS with no scanning.	3-3 SR 2.3 Use control for portable and mobile devices 3-3 SR 3.2 Malicious code protection 3-3 SR 3.4 Software and information integrity
8	**Independent, locked SIS** Good practice GOOD PRACTICE: SIS is independent, in a locked cabinet, with MOC on every change.	84.09 Operation Management of change (MOC) for SIS security 3-3 SR 7.6 Network and security configuration settings 4-2 EDR 3.11 Physical tamper resistance and detection

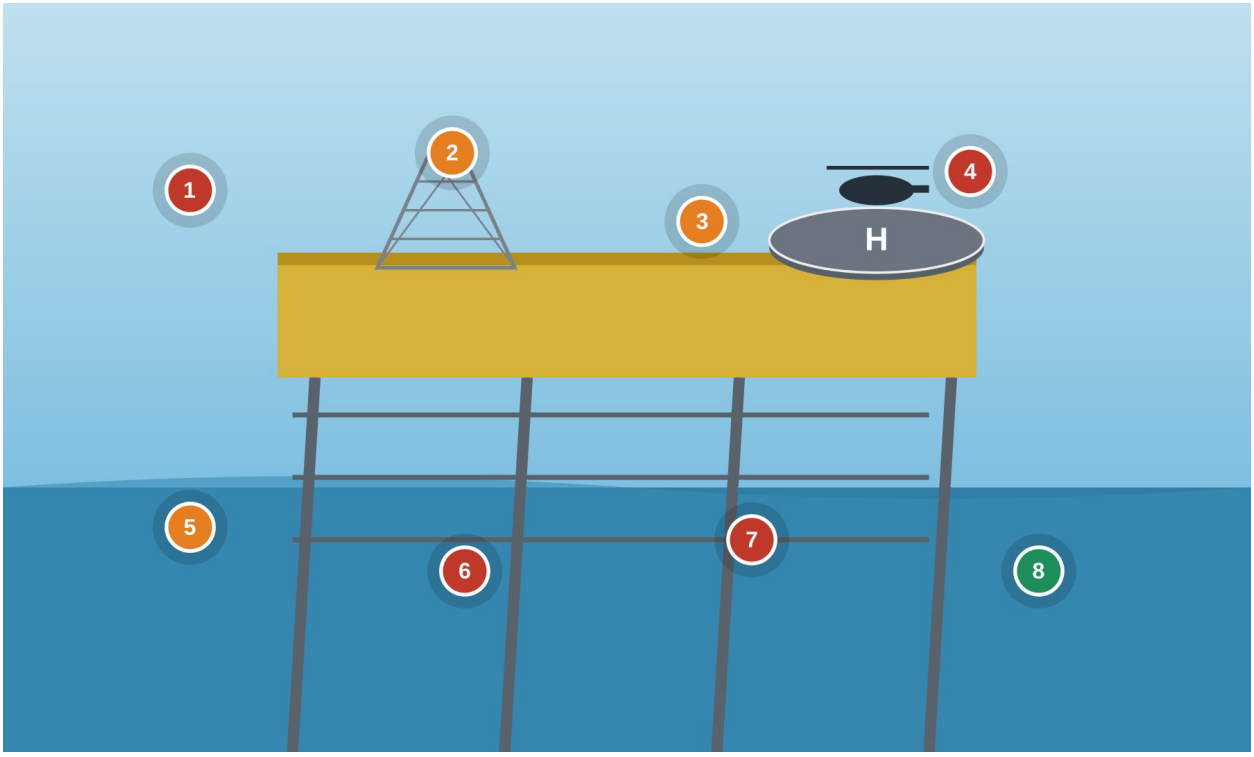
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide shot of a refinery central control room, curved wall of DCS operator consoles and large process graphics screens, distillation columns and a flare stack visible through a window. Training tells: one console is unlocked and unattended with a shared login banner, a SIS engineering workstation has a physical key-switch turned to 'PROGRAM/REMOTE', a screen shows 'Furnace trip — FORCED', an alarm screen shows dozens of shelved/nuisance alarms, a USB drive labelled 'IT patches' on the desk, a network diagram on the wall shows BPCS and SIS on the same switch. Cool control-room lighting, realistic detail, no text overlays or annotations.
```

OIL & GAS Oil & Gas — Offshore Platform & Helicopter Transfer

Offshore production — ICSS, Fire & Gas, ESD, helideck, VSAT, crew change



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. An offshore production platform. An Integrated Control & Safety System (ICSS) runs process, Fire & Gas (F&G) and Emergency Shutdown (ESD). A helideck supports crew change and refuelling; a VSAT link connects to shore; wireless IIoT sensors monitor equipment.

Key OT/IoT assets: Integrated Control & Safety System (ICSS) · Fire & Gas (F&G) system · ESD valves & logic · Helideck control & refuelling PLC · VSAT / satellite link · Wireless IIoT sensors

People & roles: Offshore Installation Manager (OIM) · Control-room operator · Instrument/automation tech · Turnaround contractor · Helicopter crew / HLO

Processes: Production control (ICSS) · Fire & Gas detection · Emergency shutdown · Helideck ops & refuelling · Crew change / turnaround

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**VSAT flat to shore** Cyber Satellite/VSAT link to shore routes flat with no firewall or zone boundary.	3-3 SR 5.2 Zone boundary protection 3-3 SR 1.13 Access via untrusted networks 4-2 NDR 5.2 Zone boundary protection
2	**F&G inhibited** Safety Fire & Gas detector outputs inhibited/forced at the HMI — detection defeated.	PLC #7 Validate and alert for paired inputs / outputs PLC #20 Trap false negatives and false positives for critical alerts 84.09 Operation Bypass / override management for the SIS
3	**Helideck PLC on process net** Safety Helideck status/refuelling PLC shares the process control network; no partitioning.	3-3 SR 5.1 Network segmentation 3-3 SR 5.4 Application partitioning PLC #13 Disable unused / unneeded communication ports and protocols

#	What to look for	Standards flagged — requirement ID & name
4	**Crew-change laptop/USB** Cyber Turnaround contractor brings an unmanaged laptop and USB onto the ICSS during crew change.	3-3 SR 2.3 Use control for portable and mobile devices 3-3 SR 3.2 Malicious code protection 4-2 CR 2.13 Use of physical diagnostic and test interfaces
5	**ESD override no confirm** Safety ESD valve in maintenance override with no independent confirmation or MOC.	84.09 Operation Management of change (MOC) for SIS security PLC #2 Track operating modes 3-3 SR 2.1 Authorization enforcement
6	**Shared OIM account** Cyber Shared 'OIM/operator' account on the ICSS; no per-user accounts.	3-3 SR 1.1 Human user identification and authentication 3-3 SR 1.3 Account management 3-3 SR 1.5 Authenticator management
7	**Open wireless IIoT** Cyber Wireless gas/vibration IIoT sensors run with no encryption or device authentication.	3-3 SR 1.6 Wireless access management 3-3 SR 2.2 Wireless use control 3-3 SR 4.3 Use of cryptography
8	**Defined safe state + recovery** Good practice GOOD PRACTICE: ICSS has a defined safe state on power loss and a tested recovery procedure.	PLC #15 Define a safe process state in case of a PLC restart 3-3 SR 7.4 Control system recovery and reconstitution 3-3 SR 7.5 Emergency power

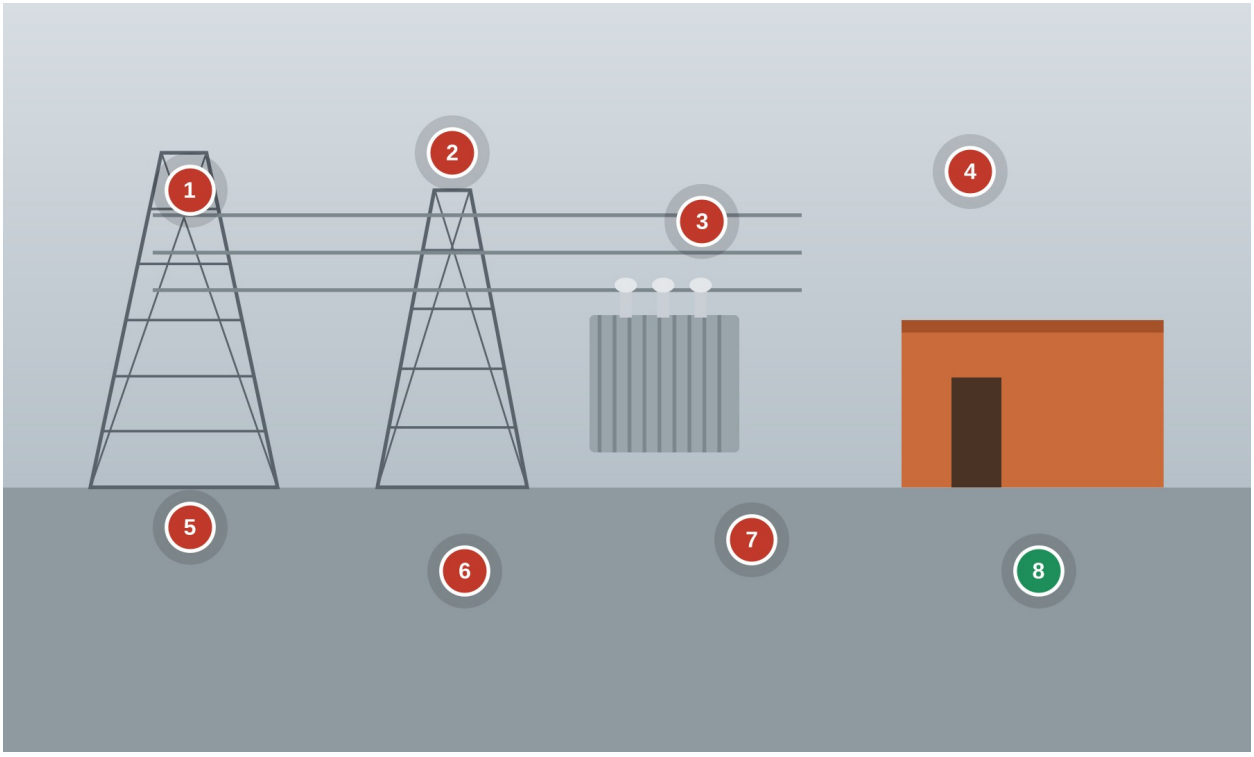
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide shot of an offshore oil platform at sea, topside process modules, a
helideck with a helicopter landing, ocean and sky behind. Training tells: a control-room
screen shows 'F&G detectors — INHIBITED', an ESD valve has a 'MAINTENANCE OVERRIDE' tag, a
VSAT dome with a network note 'no firewall to shore', a contractor carrying an open laptop
and USB drive across the deck during crew change, a sticky note 'ICSS: OIM / offshore1',
small wireless sensor pucks on pipework labelled 'open Wi-Fi'. Bright maritime daylight,
realistic offshore detail, sense of scale, no text overlays or annotations.
```

ELECTRIC Electric — Transmission Substation

HV substation — RTU, protective relays (IEC 61850), GOOSE, control house



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A high-voltage transmission substation. Protective relays (IEDs) trip breakers over an IEC 61850 station bus (GOOSE/SV); a substation RTU/gateway telemeters to the SCADA/EMS; a control house holds relay panels and the station HMI.

Key OT/IoT assets: Protective relays / IEDs · Substation RTU / gateway · IEC 61850 station bus (GOOSE/SV) · Station HMI · Power transformers & breakers · Managed station switches

People & roles: System operator (control center) · Protection & control engineer · Substation technician · Relay test contractor · Physical security / access

Processes: Protection & tripping · Remote SCADA/EMS telemetry · Relay setting changes · Firmware maintenance · Physical access control

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**Unauthenticated IEC 61850** Cyber Relay engineering access over unencrypted IEC 61850 with no device authentication.	3-3 SR 1.2 Software process and device identification and authentication 3-3 SR 3.1 Communication integrity 4-2 CR 1.2 Software process and device identification and authentication
2	**Dial-in default password** Cyber Substation RTU cellular/dial-up on a default password with no MFA.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 1.5 Authenticator management 3-3 SR 1.7 Strength of password-based authentication
3	**Laptop bridges IT/OT** Cyber Station HMI on an engineering laptop bridged to the corporate network.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 CR 5.1 Network segmentation

#	What to look for	Standards flagged — requirement ID & name
4	**Relay change, no approval/audit** Cyber Protective-relay settings can be changed with no dual-approval and no audit record.	3-3 SR 2.1 Authorization enforcement 3-3 SR 2.8 Auditable events 3-3 SR 2.12 Non-repudiation
5	**Control house unsecured** Cyber Control-house door propped open, relay panels unlocked — physical access uncontrolled.	4-2 EDR 3.11 Physical tamper resistance and detection 4-2 CR 2.13 Use of physical diagnostic and test interfaces 3-3 SR 2.1 Authorization enforcement
6	**GOOSE not monitored** Cyber GOOSE/Sampled-Value traffic is not monitored for anomalies or spoofing.	3-3 SR 6.2 Continuous monitoring 3-3 SR 3.1 Communication integrity 3-3 SR 5.1 Network segmentation
7	**Unpatched IED firmware** Cyber IED firmware unpatched with no signed-update mechanism.	4-2 EDR 3.10 Support for updates 4-2 EDR 3.14 Integrity of the boot process 3-3 SR 7.8 Control system component inventory
8	**Segmented bus + SIEM** Good practice GOOD PRACTICE: segmented station bus with switch ACLs and syslog to a SIEM.	4-2 NDR 5.2 Zone boundary protection 3-3 SR 6.1 Audit log accessibility 3-3 SR 5.1 Network segmentation

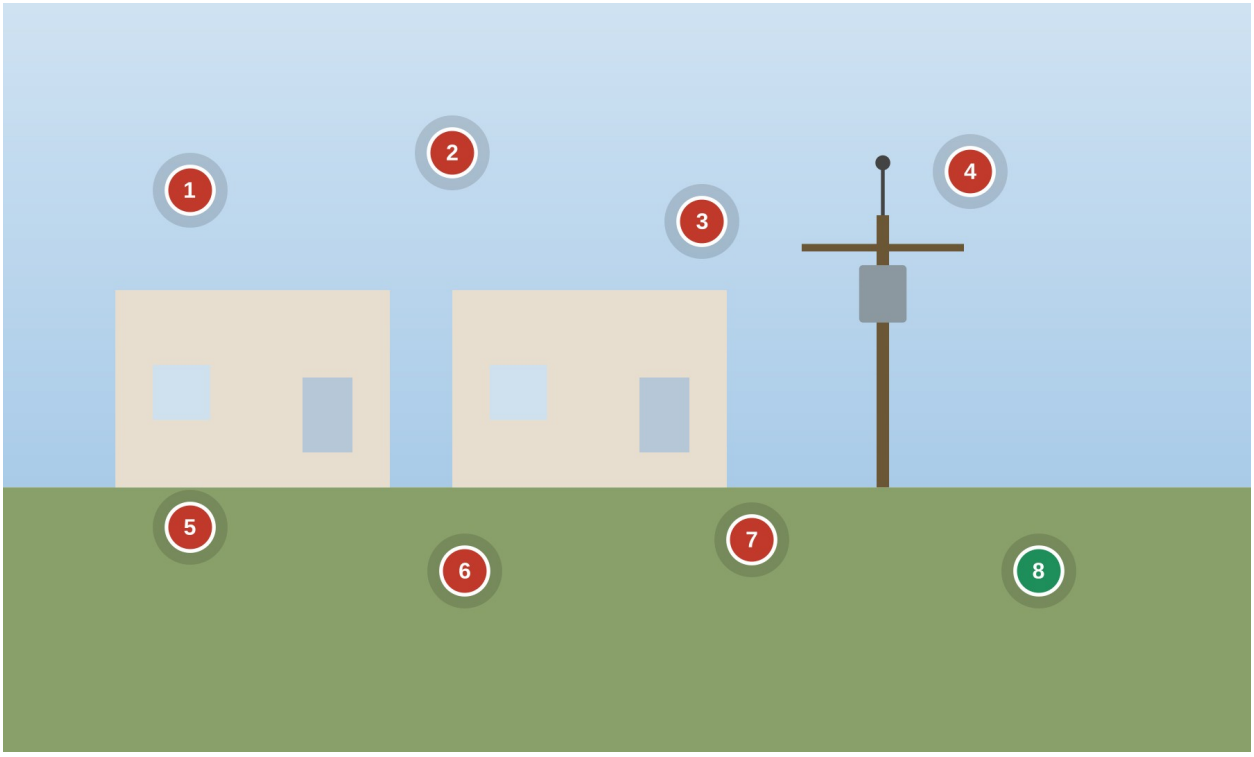
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide shot of a high-voltage electrical substation, transmission towers, large power transformers and bus work, a small brick control house. Training tells: the control-house door is propped open with no badge reader in use, inside a rack of protective relays with a panel open and a laptop wired to a relay, a screen shows 'relay settings — change (no approval)', a cellular modem with a note 'dial-in: admin/admin', a managed switch with a mirror of IT and OT cables, a sticky note 'GOOSE not monitored'. Overcast daylight, realistic utility detail, no text overlays or annotations.
```

ELECTRIC Electric — Smart Meters & Distribution Automation

AMI on homes & buildings — smart meters, RF mesh, head-end, reclosers, HAN



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. Smart meters on homes and buildings report over an RF mesh to collectors and an AMI head-end; distribution automation (reclosers, capacitor banks) is controlled in the field; home-area-network (HAN) gateways connect to meters.

Key OT/IoT assets: Residential/commercial smart meters · RF mesh + data collectors · AMI head-end system · Distribution automation (reclosers) · Home-area network (HAN) gateway · Meter disconnect switch

People & roles: Distribution operator · AMI / metering engineer · Field service technician · Utility customer · Meter data management (MDM) team

Processes: Meter reading & billing · Remote connect / disconnect · Firmware management (fleet) · Distribution automation control · Tamper / outage detection

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**Broken meter seal / local port** Cyber Meter seal broken; local optical/serial port allows on-site reprogramming.	4-2 **EDR 3.11** Physical tamper resistance and detection 4-2 **CR 2.13** Use of physical diagnostic and test interfaces 3-3 **SR 3.4** Software and information integrity
2	**Default RF-mesh keys** Cyber AMI RF mesh uses weak/default keys; traffic can be joined or read.	3-3 **SR 1.6** Wireless access management 3-3 **SR 4.3** Use of cryptography 4-2 **NDR 1.6** Wireless access management
3	**Unsigned firmware push** Cyber Head-end pushes meter firmware fleet-wide with no signature verification (mass-update risk).	3-3 **SR 3.4** Software and information integrity 4-2 **EDR 3.14** Integrity of the boot process 4-2 **EDR 3.10** Support for updates

#	What to look for	Standards flagged — requirement ID & name
4	**Disconnect not authz-controlled** Cyber Remote connect/disconnect command not authorization-controlled (mass-disconnect abuse).	3-3 SR 2.1 Authorization enforcement 3-3 SR 1.2 Software process and device identification and authentication 3-3 SR 3.5 Input validation
5	**Plaintext DNP3 recloser** Cyber Distribution recloser on cellular with plaintext DNP3 and no secure authentication.	3-3 SR 3.1 Communication integrity 3-3 SR 4.3 Use of cryptography PLC #13 Disable unused / unneeded communication ports and protocols
6	**HAN bridged to meter** Cyber Home IoT / HAN gateway bridged to the meter with no segmentation.	3-3 SR 5.1 Network segmentation 3-3 SR 5.3 General purpose person-to-person communication restrictions 3-3 SR 4.1 Information confidentiality
7	**No fleet inventory** Cyber No accurate inventory of the meter fleet; stale/unknown firmware versions in the field.	3-3 SR 7.8 Control system component inventory 3-3 SR 6.2 Continuous monitoring 4-2 EDR 3.10 Support for updates
8	**Signed FW + per-device keys** Good practice GOOD PRACTICE: meters use signed firmware, unique per-device keys and tamper alarms to the head-end.	4-2 EDR 3.12 Provisioning product supplier roots of trust 4-2 EDR 3.13 Provisioning asset owner roots of trust 3-3 SR 1.2 Software process and device identification and authentication

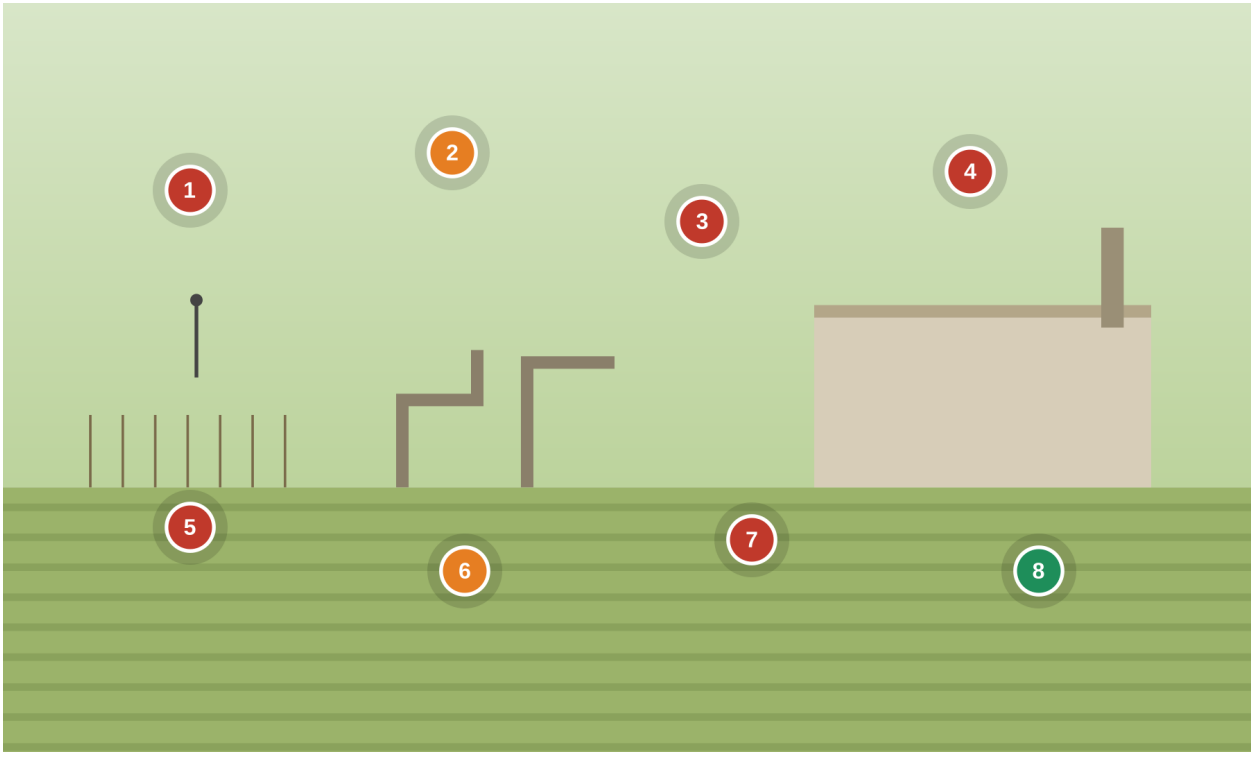
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic shot of a suburban street and a building exterior with electricity smart meters on the wall, an RF mesh antenna on a utility pole, a pole-mounted recloser. Training tells: a smart meter cover seal is broken and an optical probe is clipped to its port, a technician tablet shows 'firmware push — no signature check', a note on the collector reads 'mesh key: default', a recloser cabinet with a cellular router labelled 'DNP3 plaintext', a home IoT gateway wired to the meter. Daytime residential lighting, realistic utility detail, no text overlays or annotations.
```

NATURAL GAS Natural Gas — Farm Tap, Pipeline Station & Compression

Gas gathering — farm-tap RTU, metering, compressor ESD, odorizer, telemetry



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A natural-gas gathering system runs through farmland: a farm-tap RTU and roadside pipeline metering station telemeter over radio/cellular; a compressor station moves gas with ESD and high-pressure trips; an odorizer injects mercaptan for public safety.

Key OT/IoT assets: Farm-tap RTU / cabinet · Pipeline metering PLC · Compressor station PLC + VFD · ESD & high-pressure trip · Odorizer / injection system · SCADA telemetry radio

People & roles: Gas controller (control center) · Measurement / metering tech · Compressor-station operator · Landowner / farmer (adjacent) · Vendor remote support

Processes: Gas gathering & telemetry · Custody metering · Compression & pressure control · Odorization (public safety) · Remote vendor support

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**Open farm-tap RTU + radio** Cyber Roadside farm-tap RTU cabinet unlocked; telemetry radio unencrypted.	4-2 EDR 3.11 Physical tamper resistance and detection 3-3 SR 1.6 Wireless access management 3-3 SR 4.3 Use of cryptography
2	**Compressor ESD bypassed** Safety Compressor ESD and high-pressure trip bypassed for operations.	84.09 Operation Bypass / override management for the SIS PLC #15 Define a safe process state in case of a PLC restart PLC #2 Track operating modes
3	**Writable metering PLC** Cyber Metering PLC on writable Modbus; custody values can be spoofed (fraud).	3-3 SR 3.1 Communication integrity 3-3 SR 3.5 Input validation PLC #8 Validate HMI input variables at the PLC level, not only at the HMI

#	What to look for	Standards flagged — requirement ID & name
4	**Flat station network** Cyber Station SCADA is flat to the enterprise network with no DMZ.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 CR 5.1 Network segmentation
5	**Always-on vendor cellular** Cyber Vendor cellular remote access to the compressor VFD is always on and on default credentials.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 1.5 Authenticator management 3-3 SR 2.6 Remote session termination
6	**Odorizer alarm inhibited** Safety Odorant-injection low alarm inhibited — public-safety odorization not assured.	PLC #20 Trap false negatives and false positives for critical alerts PLC #12 Validate inputs based on physical plausibility 3-3 SR 6.2 Continuous monitoring
7	**Unauthenticated polling** Cyber Shared SCADA polling over radio with no device authentication (spoofable).	3-3 SR 1.2 Software process and device identification and authentication 3-3 SR 3.1 Communication integrity 4-2 CR 1.2 Software process and device identification and authentication
8	**Hardened field RTUs** Good practice GOOD PRACTICE: field RTUs have unused ports disabled and a signed configuration baseline.	PLC #13 Disable unused / unneeded communication ports and protocols 3-3 SR 7.6 Network and security configuration settings 3-3 SR 7.7 Least functionality

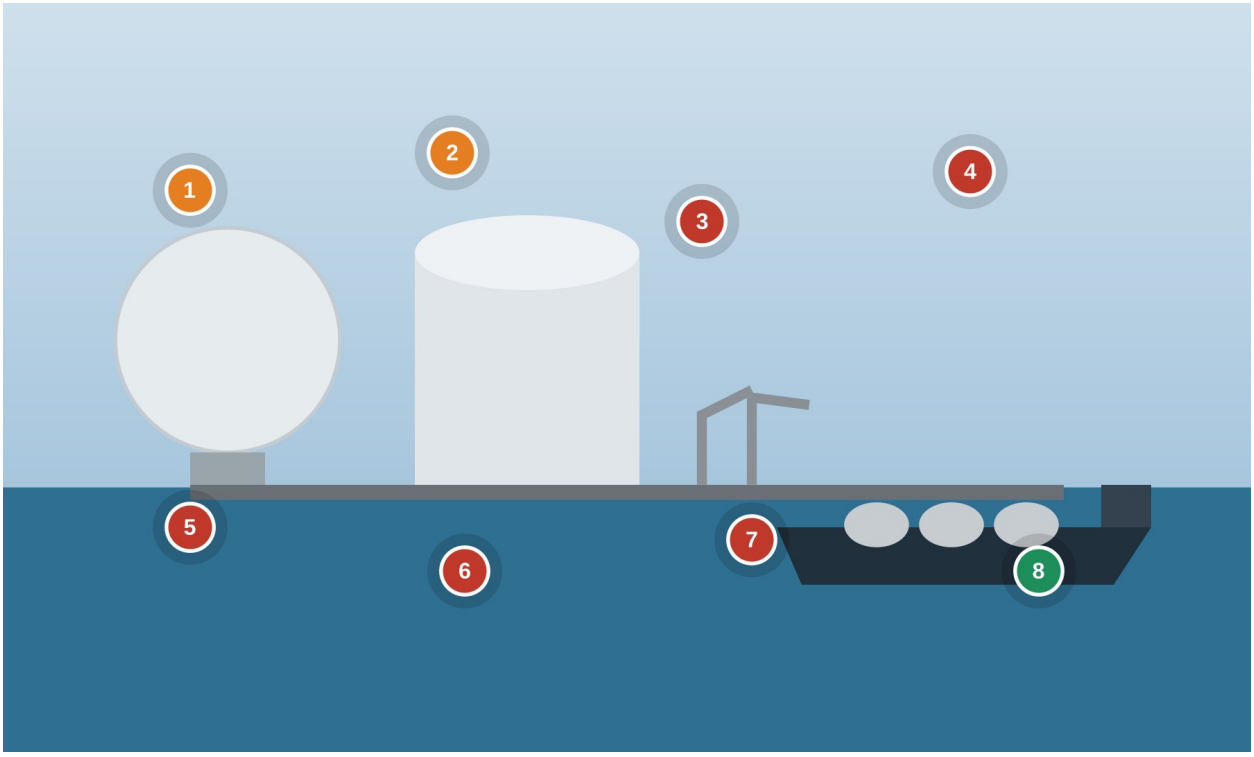
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide shot of a natural-gas pipeline metering and compressor station beside farmland, a small roadside RTU cabinet near a fence line, pipe risers and a compressor building. Training tells: the roadside RTU cabinet is unlocked and open with a radio antenna, a compressor HMI shows 'High-pressure trip — BYPASS', a metering laptop wired into an open cabinet, a note 'cell remote: default pw', an odorizer panel reads 'inject alarm INHIBITED', a network switch mixing field and office cables. Rural daylight, crops in the background, realistic detail, no text overlays or annotations.
```

NATURAL GAS Natural Gas — LNG Terminal

LNG liquefaction/regas — jetty loading arms, ship-shore link, SIS, F&G



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. An LNG terminal liquefies or regasifies gas and loads/unloads LNG carriers at a jetty. A DCS runs process; an independent SIS and Fire & Gas protect against release; loading arms and a ship-shore link (SSL) manage transfer; mooring/berth monitoring uses IIoT.

Key OT/IoT assets: LNG process DCS · Independent SIS + HIPPS · Fire & Gas (F&G) system · Jetty loading arms + ESD · Ship-shore link (SSL) · Berth / mooring IIoT monitoring

People & roles: Terminal control operator · Jetty / marine loading master · Functional safety engineer · LNG carrier crew · DCS/SIS vendor (remote)

Processes: Liquefaction / regasification · Ship loading / unloading (custody) · Emergency shutdown (ESD/ESD-2) · Fire & Gas detection · Mooring & berth monitoring

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**Jetty ESD not independent** Safety Jetty loading-arm ESD and ship-shore link are not on an independent SIS zone.	84.09 **Realization** SIS zones and conduits (SIS as a separate zone) 3-3 **SR 5.4** Application partitioning 3-3 **SR 5.1** Network segmentation
2	**F&G forced from commissioning** Safety Fire & Gas and high-level tank trips forced during commissioning and never restored.	84.09 **Operation** Management of change (MOC) for SIS security PLC **#7** Validate and alert for paired inputs / outputs PLC **#15** Define a safe process state in case of a PLC restart
3	**Unauthenticated ship-shore link** Cyber Ship-shore custody/telemetry link over unauthenticated serial/OPC.	3-3 **SR 3.1** Communication integrity 3-3 **SR 1.2** Software process and device identification and authentication 3-3 **SR 4.3** Use of cryptography

#	What to look for	Standards flagged — requirement ID & name
4	**DCS laptop shared w/ email** Cyber DCS/SIS engineering laptop also used for corporate email and internet.	3-3 SR 2.3 Use control for portable and mobile devices 3-3 SR 5.1 Network segmentation 3-3 SR 3.2 Malicious code protection
5	**Open mooring IIoT** Cyber Berth control and mooring-monitoring IIoT run wireless with no encryption.	3-3 SR 1.6 Wireless access management 3-3 SR 4.3 Use of cryptography 4-2 NDR 1.6 Wireless access management
6	**Always-on refrigeration VPN** Cyber Vendor VPN into compressor/refrigeration controls is permanently connected.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 2.6 Remote session termination 3-3 SR 6.2 Continuous monitoring
7	**Shared console, no lock** Cyber Operator consoles on shared credentials with no session lock.	3-3 SR 1.1 Human user identification and authentication 3-3 SR 2.5 Session lock 3-3 SR 1.5 Authenticator management
8	**Independent HIPPS/SIS, MOC** Good practice GOOD PRACTICE: independent HIPPS/SIS in a locked zone with MOC enforced on all changes.	84.09 Operation Management of change (MOC) for SIS security 3-3 SR 7.6 Network and security configuration settings 4-2 EDR 3.11 Physical tamper resistance and detection

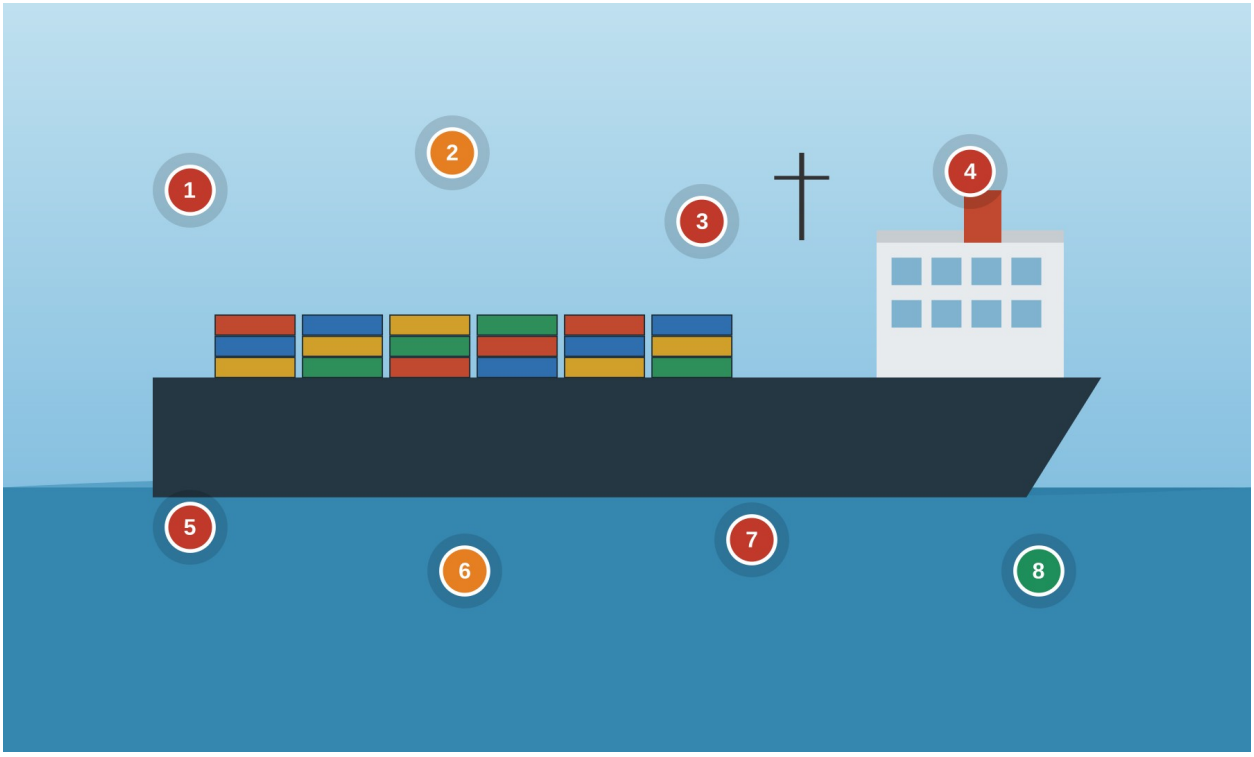
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide shot of an LNG terminal at a waterfront, large spherical and full-containment LNG storage tanks, a jetty with articulated loading arms and an LNG carrier moored alongside. Training tells: a control screen shows 'F&G / high-level trip — FORCED (commissioning)', a jetty ESD panel wired to a shared network switch, a shared operator console with 'no session lock', a ship-shore link box labelled 'serial — no auth', small wireless mooring sensors labelled 'open', a laptop with corporate email open plugged into the DCS. Coastal daylight, realistic industrial detail, sense of scale, no text overlays or annotations.
```

MARITIME Maritime — Vessel Bridge & Engine Room

Ship OT — ECDIS, IBS, GNSS, engine/propulsion PLC (PMS), VSAT



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A vessel's bridge runs an Integrated Bridge System (IBS) with ECDIS and radar fed by GNSS/GPS; the engine room runs an Integrated Automation System (IAS) / Power Management System and propulsion PLCs; VSAT and crew Wi-Fi connect the ship.

Key OT/IoT assets: ECDIS + radar (IBS) · GNSS / GPS receiver · Engine / propulsion PLC (PMS) · Integrated Automation System (IAS) · VSAT + crew Wi-Fi · Serial-to-IP OT gateways

People & roles: Master / OOW (officer of the watch) · Chief engineer · Electro-technical officer (ETO) · Crew (personal devices) · OEM remote support

Processes: Navigation (ECDIS/IBS) · Propulsion & power management · Chart & software updates · Ballast / steering control · OEM remote support

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**ECDIS USB updates** Cyber ECDIS chart/software updates loaded via crew USB with no scanning.	3-3 SR 2.3 Use control for portable and mobile devices 3-3 SR 3.2 Malicious code protection 4-2 CR 2.13 Use of physical diagnostic and test interfaces
2	**No GNSS spoof detection** Safety GNSS/GPS feeding ECDIS/DP has no jamming or spoofing detection (navigation integrity).	3-3 SR 3.5 Input validation PLC #12 Validate inputs based on physical plausibility 3-3 SR 6.2 Continuous monitoring
3	**Crew Wi-Fi bridged to nav** Cyber VSAT/crew Wi-Fi bridged flat to the navigation/IAS network.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 NDR 5.2 Zone boundary protection

#	What to look for	Standards flagged — requirement ID & name
4	**Always-on OEM satellite access** Cyber Engine/propulsion PLC (PMS) has always-on OEM remote access over satellite.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 2.6 Remote session termination 3-3 SR 6.2 Continuous monitoring
5	**Shared bridge login** Cyber Shared bridge/engine control login; no per-user accounts.	3-3 SR 1.1 Human user identification and authentication 3-3 SR 1.3 Account management 3-3 SR 1.5 Authenticator management
6	**Steering safe-state undefined** Safety Ballast/steering alarms overridden; no defined safe state on a PLC restart.	PLC #15 Define a safe process state in case of a PLC restart PLC #2 Track operating modes PLC #20 Trap false negatives and false positives for critical alerts
7	**Default gateway creds** Cyber Serial-to-IP OT gateways on default credentials with open ports.	3-3 SR 1.5 Authenticator management 3-3 SR 1.7 Strength of password-based authentication PLC #13 Disable unused / unneeded communication ports and protocols
8	**Segmented per IACS E26/E27** Good practice GOOD PRACTICE: segmented networks, signed navigation updates and an asset inventory (aligns to IACS UR E26/E27).	3-3 SR 5.1 Network segmentation 3-3 SR 7.8 Control system component inventory 4-2 EDR 3.14 Integrity of the boot process

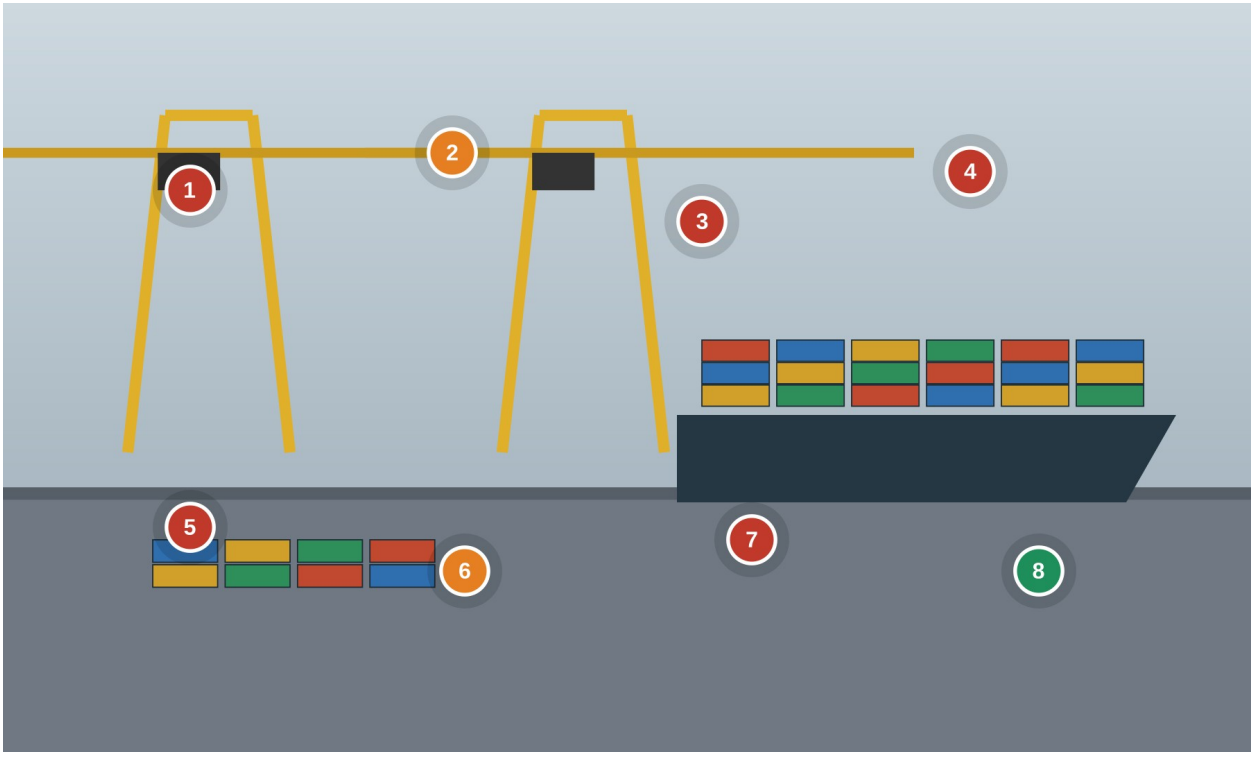
Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic shot from a ship's bridge, ECDIS and radar screens, windows over the bow at sea, and an inset of the engine control room with automation panels. Training tells: an ECDIS screen with a crew USB stick plugged in labelled 'chart update', a note 'no GPS spoof check', a crew Wi-Fi router cabled to the navigation network switch, an engine PMS screen showing 'OEM remote — always on (satellite)', a sticky note 'bridge login: master / ship123', a serial-to-IP gateway labelled 'default pw'. Marine daylight through the windows, realistic detail, no text overlays or annotations.
```

MARITIME Maritime — Port & Container Terminal

Container terminal — STS/RTG cranes, TOS, reefers, gate OCR, radio remote control



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A container terminal moves boxes with ship-to-shore (STS) and yard (RTG/RMG) cranes driven by PLCs; a Terminal Operating System (TOS) coordinates moves; reefer racks, gate OCR and radio remote-control of cranes add IoT/OT exposure.

Key OT/IoT assets: STS ship-to-shore crane PLC/drives · RTG/RMG yard crane PLC · Terminal Operating System (TOS) · Reefer monitoring / gate OCR (IoT) · Crane radio remote control · Anti-collision / load-moment interlocks

People & roles: Terminal operations controller · Crane operator / driver · Crane maintenance technician · OEM crane support (remote) · Gate / yard staff

Processes: Container handling (crane control) · Terminal operations (TOS) · Crane maintenance & programming · Reefer / gate monitoring · Radio remote crane control

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**Crane drive default creds/Wi-Fi** Cyber STS crane PLC/drive on shared Wi-Fi with default credentials and OEM remote diagnostics.	3-3 SR 1.6 Wireless access management 3-3 SR 1.13 Access via untrusted networks 3-3 SR 1.5 Authenticator management
2	**Anti-collision bypassed** Safety Crane anti-collision / load-moment safety interlock bypassed.	84.09 Operation Bypass / override management for the SIS PLC #7 Validate and alert for paired inputs / outputs PLC #15 Define a safe process state in case of a PLC restart
3	**TOS flat to crane OT** Cyber Terminal Operating System (IT) bridged flat to the crane OT network.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 CR 5.1 Network segmentation

#	What to look for	Standards flagged — requirement ID & name
4	**Internet-exposed gate/reefer IoT** Cyber Gate OCR and reefer-monitoring IoT devices on default credentials and internet-exposed.	3-3 SR 1.5 Authenticator management 3-3 SR 5.2 Zone boundary protection 3-3 SR 1.13 Access via untrusted networks
5	**USB crane programming** Cyber Contractor uses an unmanaged USB to transfer crane PLC programs.	3-3 SR 2.3 Use control for portable and mobile devices 3-3 SR 3.4 Software and information integrity 4-2 CR 2.13 Use of physical diagnostic and test interfaces
6	**Unauthenticated radio control** Safety Radio remote-control of RTG cranes is unauthenticated (spoofable command).	3-3 SR 1.6 Wireless access management 3-3 SR 2.2 Wireless use control 3-3 SR 4.3 Use of cryptography
7	**No PLC change logging** Cyber No monitoring or logging of PLC program changes on the cranes.	3-3 SR 2.8 Auditable events 3-3 SR 6.2 Continuous monitoring 3-3 SR 2.12 Non-repudiation
8	**Segmented crane zone + baselines** Good practice GOOD PRACTICE: segmented crane OT zone, switch ACLs, signed PLC baselines and a change log.	4-2 NDR 5.2 Zone boundary protection 3-3 SR 2.8 Auditable events PLC #5 Use cryptographic and/or checksum integrity checks for PLC code

Photoreal image-generation prompt

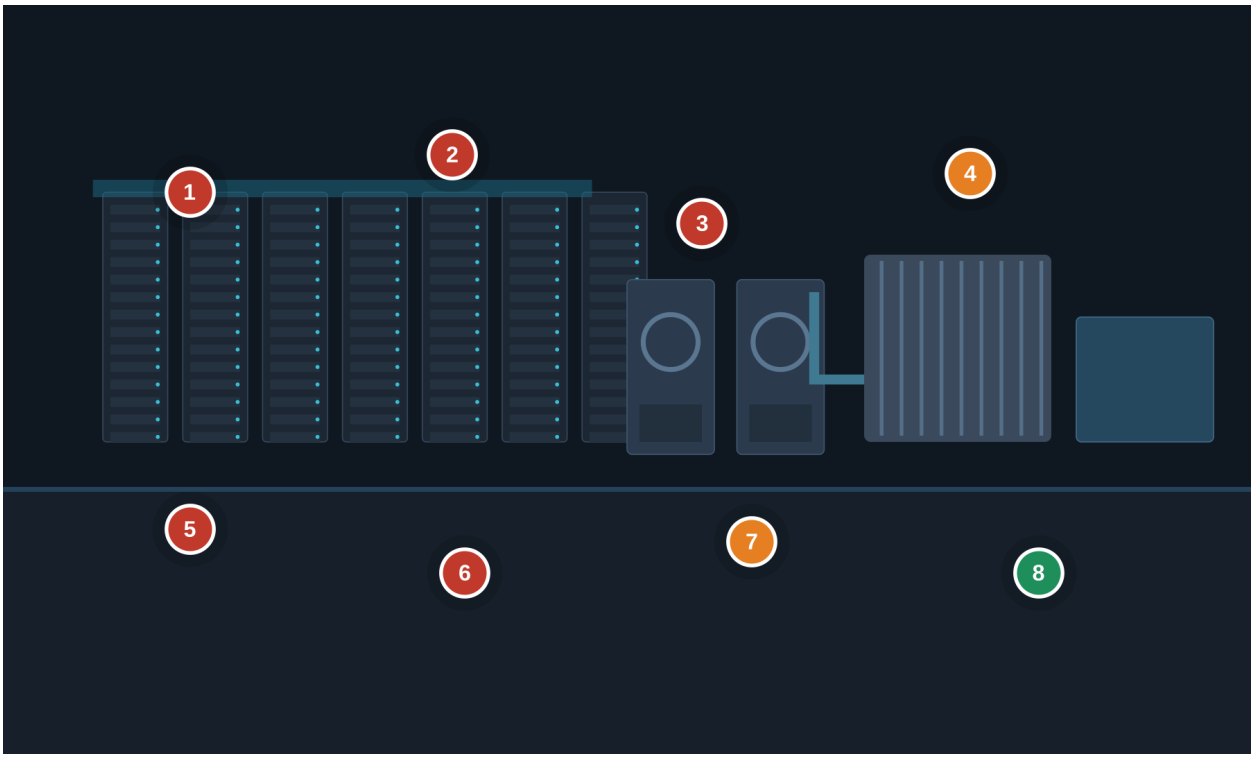
Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide shot of a container port terminal, towering ship-to-shore cranes over a container ship, stacks of colorful containers and rubber-tyred gantry cranes in the yard. Training tells: a crane machine-house PLC cabinet open with a laptop and USB drive, a Wi-Fi antenna with a note 'crane drive: admin/admin', a screen showing 'anti-collision interlock — BYPASS', a gate OCR/reefer IoT box labelled 'internet-exposed', a handheld radio remote for a yard crane, a network rack mixing TOS/IT and crane OT cables. Industrial daylight, realistic port detail, sense of scale, no text overlays or annotations.
```

BUILDINGS & FACILITIES

Data Center — Cooling & Mechanical Plant

Critical cooling — chillers, CRAH/CRAC, modular cooling, BMS/BACnet, cold-aisle containment



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A data center mechanical plant keeps the white space within temperature. Water-cooled chillers, cooling towers and pumps feed CRAH/CRAC units and containerized/modular cooling; a Building Management System (BMS/BAS) on BACnet/Modbus drives setpoints and sequencing. Loss of cooling is both an availability and an equipment-safety event.

Key OT/IoT assets: Water-cooled chiller plant · CRAH / CRAC units · Modular / containerized cooling units · Cooling tower & condenser pumps · BMS/BAS DDC controllers (BACnet/Modbus) · BMS server / operator workstation

People & roles: Critical-environment / facilities operator · BMS / controls engineer · Mechanical technician · Chiller OEM (remote support) · Data center manager

Processes: Cooling control & setpoints · Chiller sequencing & staging · BMS alarming & trending · Vendor remote maintenance · Change control (MOC)

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**Flat BMS/BACnet network** Cyber BMS/BACnet shares a flat network reachable from IT/corporate; no segmentation to the cooling controls.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 CR 5.1 Network segmentation
2	**Unauthenticated BACnet writes** Cyber BACnet/Modbus setpoints and commands can be written by anyone on the network; no device authentication.	3-3 SR 3.1 Communication integrity 3-3 SR 1.2 Software process and device identification and authentication 3-3 SR 3.5 Input validation

#	What to look for	Standards flagged — requirement ID & name
3	**Always-on chiller OEM access** Cyber Chiller OEM remote access left permanently connected on default credentials.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 1.5 Authenticator management 3-3 SR 2.6 Remote session termination
4	**Chiller trip bypassed** Safety Chiller high-pressure / high-temperature trip bypassed at the BMS to keep cooling running.	84.09 Operation Bypass / override management for the safety function PLC #2 Track operating modes PLC #12 Validate inputs based on physical plausibility
5	**Shared BMS login** Cyber Shared 'bms/operator' login on the BMS workstation; no per-user accounts.	3-3 SR 1.1 Human user identification and authentication 3-3 SR 1.3 Account management 3-3 SR 1.5 Authenticator management
6	**Default modular-cooling creds** Cyber Modular/containerized cooling unit on default web admin credentials with an exposed HTTP interface.	3-3 SR 1.5 Authenticator management 3-3 SR 1.7 Strength of password-based authentication 3-3 SR 7.7 Least functionality
7	**Failover logic not validated** Safety Cooling redundancy/failover logic unvalidated; one setpoint change can trip a whole hall.	PLC #7 Validate and alert for paired inputs / outputs PLC #11 Instrument for plausibility checks 3-3 SR 7.1 Denial of service protection
8	**Segmented, monitored BMS** Good practice GOOD PRACTICE: BMS in a segmented zone with monitored BACnet traffic and signed controller configurations.	3-3 SR 5.2 Zone boundary protection 3-3 SR 6.2 Continuous monitoring 3-3 SR 7.6 Network and security configuration settings

Photoreal image-generation prompt

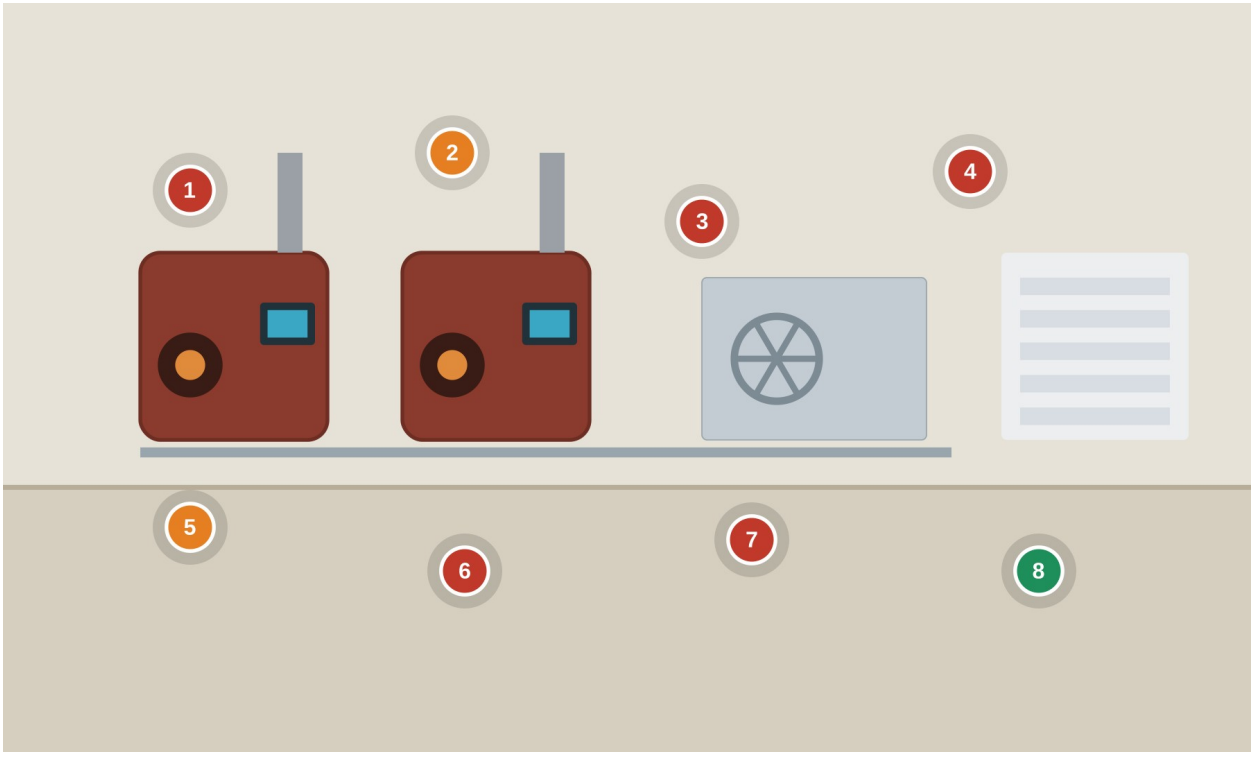
Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic wide shot inside a data center cooling and mechanical plant: rows of server racks with cold-aisle containment, large CRAH air handlers, water-cooled chillers with piping and pumps, and a containerized modular cooling unit. Training tells: a BMS operator screen showing 'Chiller high-pressure trip — BYPASS', a network switch with IT and BMS cables mixed together, a laptop plugged into a DDC controller, a sticky note 'BMS: operator/operator', a modular cooling unit web page 'admin/admin', a monitor labelled 'BACnet — no auth', an 'OEM remote access: always on' note. Cool blue LED lighting, realistic detail, no text overlays or annotations.
```

BUILDINGS & FACILITIES

Buildings — Automation & Boiler Plant

Central plant — BAS/BACnet, AHUs, hot-water/steam boilers, burner management (flame safeguard)



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A commercial building / campus central plant. A Building Automation System (BAS) on BACnet/LonWorks drives air handlers and VAV boxes; hot-water or steam boilers are protected by a burner management system (flame safeguard) and low-water cutoff — a combustion safety function (per NFPA 85 / ASME CSD-1) that a cyber event must not defeat.

Key OT/IoT assets: BAS supervisory controllers + DDC · Air handling units & VAV boxes · Hot-water / steam boilers · Burner management / flame safeguard · Building controls server · BACnet / LonWorks / Modbus field bus

People & roles: Building engineer / operator · Controls / BAS integrator · Boiler technician · OEM burner vendor · Facilities manager

Processes: HVAC scheduling & setpoints · Boiler sequencing & combustion safety · BAS trending & alarms · Integrator remote support · Change control (MOC)

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**BAS exposed to internet** Cyber BAS supervisory controller reachable from the internet on default credentials.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 1.5 Authenticator management 3-3 SR 5.2 Zone boundary protection
2	**Burner safeguard forced** Safety Boiler burner-management / flame-safeguard trip bypassed or forced (combustion / explosion hazard).	84.09 Operation Bypass / override management for the safety function PLC #15 Define a safe process state in case of a PLC restart PLC #2 Track operating modes

#	What to look for	Standards flagged — requirement ID & name
3	**Integrator laptop across sites** Cyber Integrator laptop moves between customer sites and connects to the BAS with no control or scanning.	3-3 SR 2.3 Use control for portable and mobile devices 3-3 SR 3.2 Malicious code protection 4-2 CR 2.13 Use of physical diagnostic and test interfaces
4	**Spoofable BACnet commands** Cyber BACnet broadcast with no device authentication; setpoints and commands are spoofable.	3-3 SR 1.2 Software process and device identification and authentication 3-3 SR 3.1 Communication integrity 3-3 SR 3.5 Input validation
5	**Combustion alarms inhibited** Safety High/low-fire and low-water-cutoff alarms inhibited at the BAS.	PLC #20 Trap false negatives and false positives for critical alerts PLC #7 Validate and alert for paired inputs / outputs 3-3 SR 6.2 Continuous monitoring
6	**Flat tenant/IT network** Cyber BAS shares a VLAN with tenant/guest and IT networks; no segmentation.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 CR 5.1 Network segmentation
7	**No controller backup/inventory** Cyber No configuration backup of controllers and no inventory of field devices.	3-3 SR 7.3 Control system backup 3-3 SR 7.8 Control system component inventory 3-3 SR 7.4 Control system recovery and reconstitution
8	**Independent burner management** Good practice GOOD PRACTICE: independent burner management in a locked panel, with MOC and dual-approval on changes.	84.09 Operation Management of change (MOC) for the safety function 3-3 SR 2.1 Authorization enforcement 4-2 EDR 3.11 Physical tamper resistance and detection

Photoreal image-generation prompt

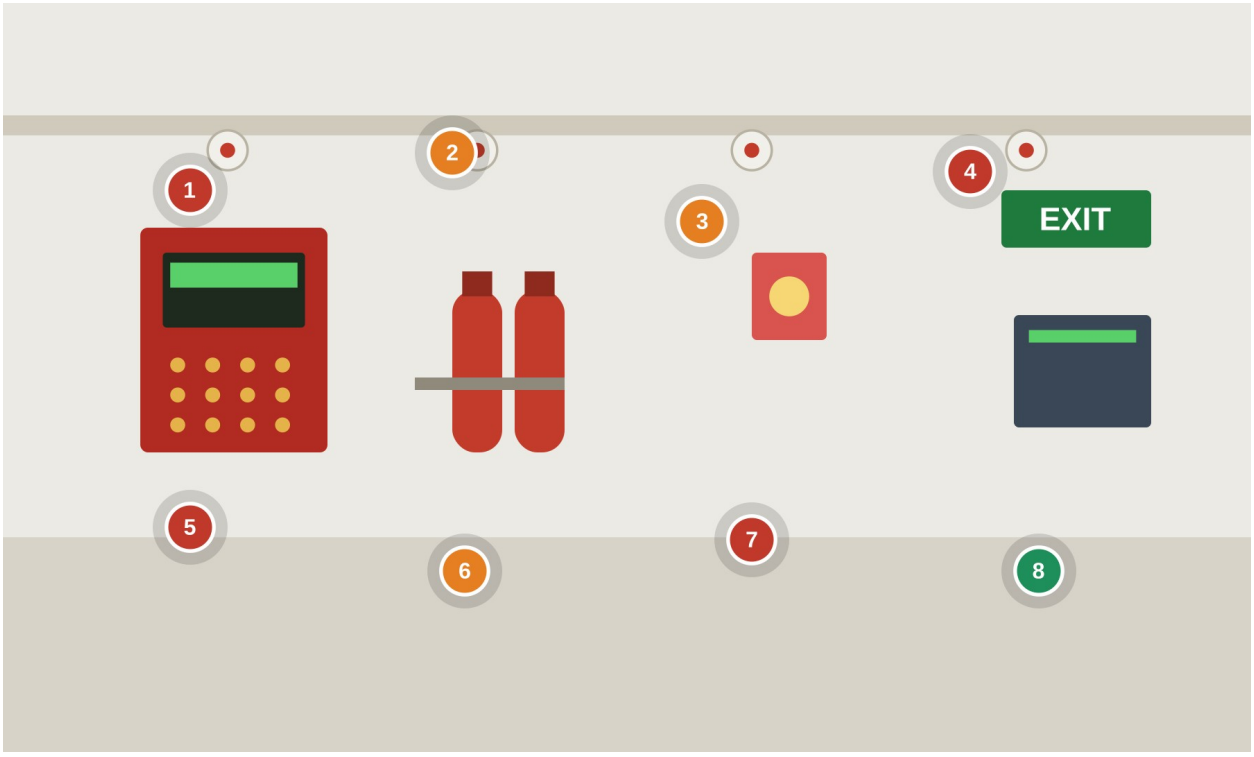
Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic shot of a commercial building mechanical / boiler room: two hot-water boilers with flue stacks and burner assemblies, an air handling unit, pumps and piping, and a wall-mounted building automation (BAS) control panel. Training tells: a BAS screen 'Burner management trip — FORCED', a low-water cutoff with a 'BYPASS' tag zip-tied to it, an integrator laptop wired into the open BAS panel, a sticky note 'BAS: admin/admin', a router labelled 'internet-exposed', a BACnet controller with its cover open. Industrial mechanical-room lighting, realistic detail, no text overlays or annotations.
```

BUILDINGS & FACILITIES

Buildings — Fire & Life Safety Systems

FACP, suppression release, smoke control, mass notification — increasingly IP-networked



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A building fire & life safety installation. A fire alarm control panel (FACP) with addressable detectors drives alarm and evacuation; suppression release (pre-action / clean-agent) and smoke-control HVAC are safety functions; mass notification / voice evacuation warns occupants. These follow NFPA 72 / life-safety codes — the flags below are the cyber overlay on top of that governance, not a replacement for it.

Key OT/IoT assets: Fire alarm control panel (FACP) · Suppression release panel (pre-action / clean-agent) · Smoke-control (HVAC interface) · Mass notification / voice evacuation · IP fire-alarm gateway · Emergency generator / ATS interface

People & roles: Fire safety director · Life-safety / fire-alarm technician · BAS integrator · Authority Having Jurisdiction (AHJ) · Security operations

Processes: Detection & alarm · Suppression release logic · Smoke-control sequencing · Mass notification · Testing / inspection & MOC

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**FACP on IT network** Cyber Fire alarm panel networked to BAS/IT with no segmentation or firewall.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 NDR 5.2 Zone boundary protection
2	**Suppression release bypassed** Safety Pre-action / clean-agent suppression release can be disabled from a networked HMI with no control.	84.09 Operation Bypass / override management for the safety function PLC #2 Track operating modes 3-3 SR 2.1 Authorization enforcement

#	What to look for	Standards flagged — requirement ID & name
3	**Smoke-control spoofable** Safety Smoke-control HVAC sequence integrity not protected; BACnet commands are spoofable.	3-3 SR 3.1 Communication integrity 3-3 SR 3.5 Input validation PLC #7 Validate and alert for paired inputs / outputs
4	**Plaintext fire gateway** Cyber IP fire-alarm gateway on default credentials, reporting off-site over plaintext.	3-3 SR 1.5 Authenticator management 3-3 SR 3.1 Communication integrity 3-3 SR 4.3 Use of cryptography
5	**Mass-notification reachable** Cyber Mass notification / voice evac reachable from IT with no authentication (false alerts or silencing).	3-3 SR 1.2 Software process and device identification and authentication 3-3 SR 2.1 Authorization enforcement 3-3 SR 5.2 Zone boundary protection
6	**Zones left disabled** Safety Detector/zone disable and walk-test left active, suppressing real alarms.	PLC #20 Trap false negatives and false positives for critical alerts PLC #2 Track operating modes 3-3 SR 6.2 Continuous monitoring
7	**No change control on panel** Cyber No change control or audit on fire-panel programming changes.	3-3 SR 2.8 Auditable events 3-3 SR 2.12 Non-repudiation 84.09 Operation Management of change (MOC) for the safety function
8	**Segmented life-safety net** Good practice GOOD PRACTICE: life-safety network segmented and monitored; panel programming under MOC with AHJ sign-off.	84.09 Operation Management of change (MOC) for the safety function 3-3 SR 5.2 Zone boundary protection 3-3 SR 6.2 Continuous monitoring

Photoreal image-generation prompt

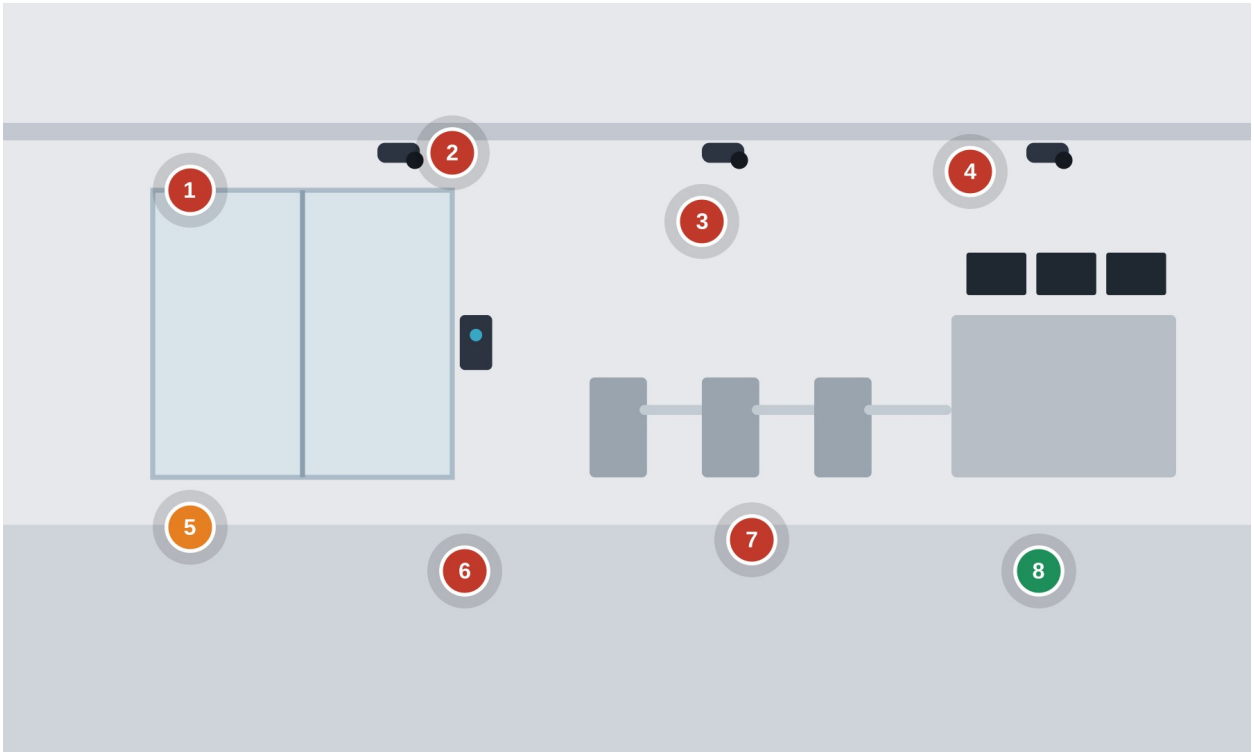
Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic shot of a building fire & life safety installation: a red fire alarm control panel (FACP) on the wall with a status display, ceiling smoke detectors, clean-agent suppression cylinders and a pre-action valve, a wall voice-evacuation speaker/strobe and an illuminated green EXIT sign. Training tells: the FACP display reads 'ZONE DISABLED / WALK TEST', a suppression release panel with a 'BYPASS' tag, an IP network gateway labelled 'plaintext reporting / default pw', a laptop cabled into the panel, a note 'fire net on IT VLAN'. Realistic building-interior lighting, no text overlays or annotations.
```

BUILDINGS & FACILITIES

Buildings — Physical Access Control & Security

PACS — IP door controllers, card readers (Wiegand/OSDP), CCTV/VMS, intrusion, elevator/turnstiles



Numbered markers = planted findings. ● cyber ● safety ● good practice

Setting. A physical security system for a building or critical site. A Physical Access Control System (PACS) with IP door controllers and card readers governs badge access and electric locks; CCTV cameras feed a VMS/NVR; intrusion detection, turnstiles/mantraps and elevator access round it out. PACS is the cyber-physical gateway to substations, data-center white space and control rooms.

Key OT/IoT assets: PACS door controllers · Card / badge readers (Wiegand / OSDP) · CCTV cameras & VMS / NVR · Intrusion detection panel · Turnstiles / mantrap & elevator control · Access control server + directory

People & roles: Physical security manager · Security operations center (SOC) operator · PACS / CCTV integrator · Facilities · Employees & visitors

Processes: Badge access & authorization · Video surveillance & retention · Alarm monitoring & response · Visitor management · Credential lifecycle

What to look for

#	What to look for	Standards flagged — requirement ID & name
1	**Cleartext Wiegand readers** Cyber Readers wired Wiegand (cleartext) rather than OSDP Secure; card data can be sniffed or replayed.	3-3 SR 3.1 Communication integrity 3-3 SR 4.3 Use of cryptography 3-3 SR 1.2 Software process and device identification and authentication
2	**Default-cred IP cameras** Cyber IP cameras / NVR on default credentials, internet-exposed or shared with IT.	3-3 SR 1.5 Authenticator management 3-3 SR 5.2 Zone boundary protection 3-3 SR 1.13 Access via untrusted networks
3	**Flat door-controller net** Cyber Door controllers on a flat network with corporate; no segmentation.	3-3 SR 5.1 Network segmentation 3-3 SR 5.2 Zone boundary protection 4-2 CR 5.1 Network segmentation

#	What to look for	Standards flagged — requirement ID & name
4	**Shared PACS admin, no audit** Cyber PACS server unpatched on a shared admin account; door commands are not attributed or audited.	3-3 SR 1.1 Human user identification and authentication 3-3 SR 2.8 Auditable events 3-3 SR 2.12 Non-repudiation
5	**Unlock override enabled** Safety Door 'free-egress / unlock schedule' override left enabled; fail-safe vs fail-secure not managed.	PLC #2 Track operating modes PLC #15 Define a safe process state in case of a PLC restart 3-3 SR 2.1 Authorization enforcement
6	**Unpatched, tamperable devices** Cyber Camera/reader firmware unpatched with no signed updates; devices physically accessible and tamperable.	4-2 EDR 3.11 Physical tamper resistance and detection 4-2 EDR 3.10 Support for updates 4-2 CR 2.13 Use of physical diagnostic and test interfaces
7	**Always-on VMS/PACS access** Cyber VMS/PACS integrator remote access left permanently connected on default credentials.	3-3 SR 1.13 Access via untrusted networks 3-3 SR 1.5 Authenticator management 3-3 SR 2.6 Remote session termination
8	**OSDP-secure, segmented, logged** Good practice GOOD PRACTICE: OSDP-secure readers, segmented PACS/VMS zone, per-user accounts with logged door commands and signed firmware.	3-3 SR 3.1 Communication integrity 3-3 SR 2.8 Auditable events 4-2 EDR 3.14 Integrity of the boot process

Photoreal image-generation prompt

Feed this to your image tool to render a photoreal "spot-the-issue" base scene matching the corporate example.

```
Photorealistic shot of a corporate building secure entrance: optical turnstiles and a mantrap door, badge/card readers beside glass doors, an electric door lock, ceiling CCTV cameras, and a security desk with a video wall (VMS). Training tells: a reader with exposed cabling labelled 'Wiegand — cleartext', an NVR/camera screen 'admin/admin', an open door-controller cabinet with a laptop wired in, a monitor 'PACS remote access: always on', a note 'cameras on corp VLAN', and a side security door propped open. Realistic lobby lighting, no text overlays or annotations.
```